

Data Access, Privacy, and AI Usage Policy

Policy ID	POL-SEC-001	Version	2.0
Status	SUPERSEDED	Effective Date	2025-01-01
Review / End Date	2025-12-31	Supersedes	1.0
Policy Owner	Information Security and Data Governance	Business Unit	ENTERPRISE
Jurisdiction	GLOBAL	Classification	INTERNAL CONFIDENTIAL
Access Scope	ROLE_BASED	Synthetic Document	YES

Document control: The applicable policy is the version whose effective-date range contains the business date and whose status is ACTIVE. A higher future version must not be used for current decisions.

1. Policy Objective

This policy supports production-grade asset-servicing controls and AI-assisted operations. Decisions must be grounded in authorized sources, linked to the correct business date, and preserved with sufficient evidence for audit and independent review.

2. Purpose and Scope

Defines requirements for confidential data, customer information, AI-assisted processing, logging, masking, and controlled system access. Every material action must include user identity, source-system reference, policy citation, timestamp, and escalation evidence when applicable.

3. Sensitive Data Handling

Mask or tokenize direct identifiers and restricted fields before non-essential prompts, traces, analytics, and lower environments. Every material action must include user identity, source-system reference, policy citation, timestamp, and escalation evidence when applicable.

4. AI and Tool Access

Agents must use governed interfaces, least privilege, approved schemas, input validation, authorization, and immutable audit logs. Every material action must include user identity, source-system reference, policy citation, timestamp, and escalation evidence when applicable.

5. Monitoring and Retention

Log security events, model interactions, tool calls, and policy decisions under approved retention and access rules. Every material action must include user identity, source-system reference, policy citation, timestamp, and escalation evidence when applicable.

6. Current Version-Specific Rules

Control	Requirement in v2.0
PII masking	Required outside approved systems
Privileged access review	Semi-annual
AI trace redaction	Required for direct identifiers
Audit retention	6 years

Control principle: live operational status comes from governed source-system tools; policy documents provide rules, required actions, and escalation criteria.

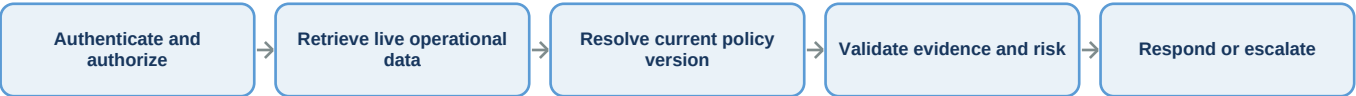
Required Evidence and Data Controls

Area	Minimum production requirement
Identity	Authenticated user, role, business unit, and permitted account/client scope
Source data	Current timestamp, source-system identifier, validated business keys, and freshness status
Policy evidence	Policy ID, applicable version, effective range, section, and citation location
AI processing	PII masking result, prompt version, model/deployment, retrieval set, and confidence signals
Audit	Trace ID, tool-call records, response outcome, escalation decision, and reviewer where needed

Key Definitions

Applicable version: the authorized version active for the business date. **Governed tool:** an approved interface that validates identity, permissions, parameters, and audit evidence before reading an operational system. **Material case:** an item whose amount, age, deadline, client impact, repeated occurrence, or regulatory sensitivity requires enhanced review.

Operational Control Flow



Roles and Responsibilities

Role	Primary responsibility
Operations Analyst	Investigate assigned items, validate evidence, document actions, and escalate when required.
Team Lead / Checker	Review sensitive or high-value actions, validate policy use, and approve controlled overrides.
Policy Control	Maintain versions, effective dates, interpretation guidance, and formal exceptions.
AI / Technology Platform	Maintain access controls, approved integrations, retrieval quality, monitoring, and failure handling.
Information Security	Define masking, secrets, privileged access, incident response, and monitoring requirements.

Audit, Privacy, and AI Requirements

- Record policy ID, version, page or section, query timestamp, user identity, access scope, and decision outcome.
- For live lookups, record MCP tool name, approved parameters, authorization result, response timestamp, and source-system reference.
- Mask PII and confidential fields in prompts and traces unless the value is explicitly required and permitted for the task.
- Scope semantic-cache entries by user authorization, business unit, policy version, and effective date; invalidate them when policy status changes.
- Route conflicting evidence, unavailable tools, restricted access, and low-confidence or high-risk cases to human review.

Test Scenarios

Scenario	Expected behavior
Older policy chunk ranks higher	Use the applicable ACTIVE version and suppress superseded guidance.
Future policy has highest version	Do not use it before its effective date.
User lacks account permission	Return an authorization-safe response without restricted details.
Cached answer uses older version	Bypass or invalidate cache and regenerate with current policy.
Live status differs from document example	Use governed live data for status and policy only for rules.

Monitoring and Acceptance Criteria

Control metric	Expected production behavior
Policy-version accuracy	Current applicable version selected for the business date; future and superseded versions excluded
Retrieval quality	Relevant section appears in top results and citations match returned evidence
Tool governance	Every live lookup is authorized, parameter-validated, rate-limited, and auditable
Privacy	Sensitive values are minimized and redacted from cache, prompts, traces, and logs
Response quality	Answer is grounded, cites evidence, distinguishes live facts from policy, and escalates uncertainty

Implementation Notes for the AI Copilot

The Retrieval Agent searches approved policy content using hybrid retrieval and metadata filters. The Policy Validation Agent confirms status, effective dates, and conflicts. Operational agents use MCP tools for current records. The Orchestrator aggregates all agent outputs and sends one structured evidence package to the Response Module for grounded answer generation, citations, masking, confidence assessment, and escalation.

End of controlled synthetic document. Structured for OCR/layout extraction, document-aware chunking, metadata enrichment, version-aware retrieval, citations, PII controls, semantic-cache invalidation, and policy validation.